

Platform Worktree — Implementation Report

Trovemo / litemall · Worktree `../litemall-wt/platform (branch fix/platform)` · Reviewed 2026-08-06

Summary: The platform worktree contains nothing unmerged. Branch `fix/platform` is **0 commits ahead** of master (120 behind — stale since mid-July 2026) and its working tree is clean. Everything it implemented — **Wave 7, production readiness** (commit `b385a99a2`, merged 2026-07-17) — is in master and is the foundation of the production stack now live at <https://trovemo.com>.

What Wave 7 delivered

The worktree's one substantive commit took the project from "never deployed, does not build from a clean checkout" to a deployable production stack, in five tasks:

Task A — Containerize the real architecture

- Single multi-stage `docker/Dockerfile`: shared Maven reactor builder plus a thin non-root JDK-21 runtime layer per service; container-aware heap via `MaxRAMPercentage` (verified: 384 MB heap under a 512 MB limit); `tini` for clean SIGTERM handling. A build step asserts each gateway jar actually contains its SPA — it caught silent packaging failures twice.
- `docker-compose.prod.yml`: the 19-container stack (9 services + MySQL, Elasticsearch, 3× OCS, Redis, RabbitMQ, Kafka/ZK, Caddy) with healthchecks, memory limits, and `${VAR:?}` secrets that abort naming the missing variable.
- Deleted 46 files of dead monolith-era deploy artifacts and removed real hazards: an Elasticsearch JDWP debug agent bound to `*:8000` (remote code execution), and a Keycloak container — rejected by the locked auth design — that published `admin/admin` and shipped a committed client secret.

Task B — Prod profiles + secrets out of the repo

- Nine `application-prod.yml` files (INFO logging, prod pool sizing, health-only actuator).
- Every secret moved to env vars with no committed fallback: Tencent COS, WeChat, Stripe, both CJ keys, gateway-admin's RSA key, machine-client secrets, the DB password. A live Stripe *secret* key had been shipped into the admin browser bundle.

- `JwtKeyGuard` (authserver + both gateways): prod fails fast instead of silently generating an ephemeral JWT signing key — the authserver had been re-keying itself on every restart.
- Locked down the config server's writable unauthenticated `POST /admin/env` ; untracked 20 SQL dumps (40 MB, including the bcrypt admin hash).

Task C — TLS + ingress

- Caddy terminates TLS for both gateways — auto-issuance/renewal, HSTS, HTTP→HTTPS — and is the only container published to the host.
- Real CORS origin via the prod profile (the default hardcoded the localhost:9000 dev server). The Cloudflare DNS-01 custom Caddy build (`docker/caddy/Dockerfile`) followed in later deployment work.

Task D — CI that actually runs

- The old workflow built on JDK 8/11 (the reactor needs 21) and npm-tested two SPAs deleted in Wave 4 — nothing had been verified in months.
- Rewritten: JDK 21, the real reactor, both SPAs with the jar-contains-SPA assertion, compose + Caddyfile validation, and gitleaks secret scanning.
- Lifted the global `maven.test.skip` master switch that had been hiding test rot, and fixed what it was hiding.

Task E — Enforce the single-replica constraint

- `replicas: 1` across the stack plus a banner naming all 14 unguarded `@Scheduled` jobs — the trap being a future operator scaling out and silently double-charging the CJ API or double-mailing customers.

Clean-checkout breaks found by building, not reading

Break	Resolution
<code>goodsapi-analytic</code> does not compile (<code>javax.*</code> under Boot 3) and registered in Eureka under goods-management's name	Excluded from the reactor
<code>goods-management</code> runs <code>vite build</code> with no vite (JHipster scaffolding)	Two-pass Maven build in the Dockerfile
<code>gateway-api</code> missing <code>@types/react-dom</code> , masked by workspace hoisting	Dependency added

<code>gateway-admin</code> SPA never bundled by Maven (checksum dirty-skip)	Fixed; guarded by the jar assertion
<code>litemall-core</code> orphan test; <code>litemall-order</code> test tree does not compile	Excluded in CI with a DELETE-THIS marker (order's to fix)
<code>-DskipTests</code> vs <code>-Dmaven.test.skip</code> are not interchangeable	Both applied where needed

Verification stated in the commit

Verified: all 9 images build; both SPAs present in their jars; non-root; JDK 21; container-aware heap; compose renders with only Caddy host-exposed; Caddyfile valid per the caddy binary; a missing secret aborts the run; gitleaks reports only the 2 files owned by order/gateway-api.

Deliberately unclaimed at the time: CI green (needed a push — testcontainers made local simulation meaningless) and A-grade TLS + Stripe webhook delivery (needed the real domain and VPS). Both were subsequently proven by the live trovemo.com deployment.

Breaking change for local dev: `litemall-db` no longer carries a password default — export `MYSQL_PASSWORD` before starting any service.

Current status & open follow-up

- **Parked.** CLAUDE.md assigns the platform worktree no active task ("do not start work here without a new instruction").
- **Known follow-up if picked up:** the CI gitleaks job was left RED on master pending credential rotation, per `docs/handoff-secrets-wave7.md`.
- The branch is fully contained in master; the worktree can be fast-forwarded to master or left as-is with no risk of losing work.